🛟 Incident Response Plan

capybara Unlimited

INCIDENT RESPONSE PLAN

An **Incident Response Plan (IRP)** provides a structured approach for detecting, responding to, and recovering from cybersecurity incidents. Below is a detailed IRP tailored for a cybersecurity team associated with Capybara Unlimited, a medium-sized organization.

By integrating this detailed IRP, cybersecurity teams can ensure they are prepared to handle incidents efficiently and minimize their impact on the organization.

🏆 I. Objectives

I Objectives

I.1 Minimize Impact:

Reduce damage to systems, data, and operations.

I.2 Restore Operations:

Resume business processes and IT systems promptly.

I.3 Enhance Security Posture:

Identify vulnerabilities exploited during the attack and implement improvements to defenses.

I.4 Meet Regulatory Requirements:

Ensure compliance with legal, industry, and organizational policies.

I.5 Improve Communication and Coordination:

Facilitate effective communication among stakeholders and coordinate response efforts efficiently.

I.6 Document and Report:

Maintain thorough documentation of all incident response activities and generate reports for audit and compliance purposes.

🔭 II. Scope

II Scope

Covers all IT systems, networks, applications, hardware, financial systems (PCI), and personnel. Including internal staff, third-party vendors, and cloud-based services.

🕵️ III. Roles & Responsibilities

III Roles & Responsibilities

The IR team consists of:

III.1 Incident Command

Oversees the response process, ensuring decisions align with organizational objectives.

III.2 SOC Analysts

Detects and analyzes threats using SIEM, EDR, and forensic tools; monitor alerts continuously to identify potential incidents.

III.3 Public Relations (PR)

Manage communications with the public and media to maintain reputation and ensure consistent and accurate messaging during and after an incident.

III.4 IT Administrators

Implement containment, eradication, and recovery steps.

III.5 Legal and Compliance Team

Ensure adherence to regulatory requirements, handle incident reporting obligations, and provide guidance on legal considerations.

III.6 All Employees or General Workforce

Share general information about the incident with all employees at each step of IR progress. Employee trust (critical during an incident) is maintained by this level of transparency. Ensures any employees with relevant information will be able to come forward ASAP. No useful information is lost within chains of tiered communication.

🌱 IV. Incident Response Lifecycle

IV Incident Response Lifecycle

Follow the **NIST Cybersecurity Framework's Incident Response Process**:

- IV.1 Preparation
  - IV.1.1 Develop policies
  - IV.1.2 Train personnel
  - IV.1.3 Implement tools
  - IV.1.4 Create playbooks
  - IV.1.5 Establishing Communication Protocol
- IV.2 Detection and Analysis
  - IV.2.1 Identify incidents
    - IV.2.1.a SIEM
    - IV.2.1.b EDR
    - IV.2.1.c Network logs
  - IV.2.2 Classify incidents
    - IV.2.2.a Severity levels
    - IV.2.2.b Type
  - IV.2.3 Collect evidence
    - IV.2.3.a Logs
    - IV.2.3.b Malware
    - IV.2.3.c Email headers
  - IV.2.4 Decision points
    - IV.2.4.a Escalate to leadership
    - IV.2.4.b Scope-based containment
- IV.3 Containment

- IV.3.1 Immediate steps
  - IV.3.1.a Affected systems
  - IV.3.1.b Affected accounts
  - IV.3.1.c Firewall rules
- IV.3.2 Short-term actions
  - IV.3.2.a Disable infected devices
  - IV.3.2.b Redirect to alternative systems
- IV.3.3 Long-term actions
  - IV.3.3.a Patch management
  - IV.3.3.b Network segmentation
- IV.4 Eradication
  - IV.4.1 Remove malware
    - IV.4.1.a Remove infection (automated)
    - IV.4.1.b Remove infection (manual)
  - IV.4.2 Address root cause
    - IV.4.2.a Root cause analysis
    - IV.4.1.b Remove persistence mechanisms
- IV.5 Recovery
  - IV.5.1 Restore operations
    - IV.5.1.a Restore from backup
    - IV.5.1.b Validate backup integrity
  - IV.5.2 Monitor post-incident
    - IV.5.2.a Watch for re-infection
    - IV.5.2.b Reduce visibility gaps
- IV.6 Post-Incident Analysis
  - IV.6.1 Conduct review
    - IV.6.1.a Create timeline
    - IV.6.1.b Evaluate processes
  - IV.6.2 Document findings
    - IV.6.2.a Incident report
    - IV.6.2.b Lessons learned
  - IV.6.3 Implement changes
    - IV.6.3.a Update IR processes
    - IV.6.3.b Implement mitigations

IV.1 Preparation

IV.1.1 Develop policies

Define incident types, severity levels, and escalation paths.

IV.1.2 Train personnel

Regularly conduct training and tabletop exercises.

IV.1.3 Implement tools

Ensure availability of SIEM, IDS/IPS, forensic tools, and backup systems.

IV.1.4 Create playbooks

Tailor playbooks for specific incidents (*e.g.*, malware incidents, phishing, DoS attacks).

IV.1.5 Establishing Communication Protocols and Escalation Procedures

Set up clear communication channels for reporting and handling incidents. Define an escalation matrix to involve the right stakeholders at the appropriate time.Use a secure chat group and automated alerts for quick response during breaches.

IV.2 Detection and Analysis

IV.2.1 Identify incidents

Monitor systems for suspicious activity using:

IV.2.1.a SIEM

SIEM dashboards for anomaly detection.

IV.2.1.b EDR

EDR alerts for malware.

IV.2.1.c Network logs

Logs for unusual network traffic.

IV.2.2 Classify incidents

Classify incidents in terms of **severity** and **type**.

IV.2.2.a Severity levels

- Low
- Medium
- High
- Critical

IV.2.2.b Type

- Malware
- Phishing
- Insider threat
- DoS/DDoS
- Data Breach

IV.2.3 Collect evidence

IV.2.3.a Logs

Logs (system, application, network).

IV.2.3.b Malware

Malware samples.

IV.2.3.c Email headers

Email headers for phishing attempts.

IV.2.4 Decision points

IV.2.4.a Escalate to leadership

Escalate to leadership for high-severity incidents.

IV.2.4.b Scope-based containment

Determine containment steps based on scope.

IV.3 Containment

IV.3.1 Immediate steps

IV.3.1.a Affected systems

Disconnect and isolate systems from the network.

IV.3.1.b Affected accounts

Quarantine compromised accounts.

IV.3.1.c Firewall rules

Block malicious IPs or URLs at the firewall level.

IV.3.2 Short-term actions

IV.3.2.a Disable infected devices

Disable infected devices but preserve forensic evidence.

IV.3.2.b Redirect to alternative systems

Redirect legitimate traffic away from targeted systems.

IV.3.3 Long-term actions

IV.3.3.a Patch management

Patch vulnerabilities.

IV.3.3.b Network segmentation

Strengthen network segmentation to limit lateral movement.

IV.4 Eradication

IV.4.1 Remove malware

IV.4.1.a Remove infection (automated)

Reboot and update infected devices to remove malware infection.

IV.4.1.b Remove infection (manual)

Manually delete malicious files, processes, and registry entries if needed.

IV.4.2 Address root cause

IV.4.2.a Root cause analysis

Investigate how the threat bypassed defenses.

IV.4.1.b Remove persistence mechanisms

Remove persistence mechanisms, such as scheduled tasks or malicious user accounts.

IV.5 Recovery

IV.5.1 Restore operations

IV.5.1.a Restore from backup

Rebuild affected systems from known-good backups.

IV.5.1.b Validate backup integrity

Validate system integrity and ensure no residual threats exist.

IV.5.2 Monitor post-incident

IV.5.2.a Watch for re-infection

Closely watch affected systems for signs of re-infection.

IV.5.2.b Reduce visibility gaps

Use enhanced logging and detection rules for similar attack vectors.

IV.6 Post-Incident Analysis

IV.6.1 Conduct review

IV.6.1.a Create timeline

Create a timeline of the incident.

IV.6.1.b Evaluate processes

Evaluate the effectiveness of detection, containment, eradication, and recovery.

IV.6.2 Document findings

IV.6.2.a Incident report

Write a comprehensive incident report.

IV.6.2.b Lessons learned

Summarize lessons learned and proposed improvements.

IV.6.3 Implement changes

IV.6.3.a Update IR processes

Update the IRP and playbooks.

IV.6.3.b Implement mitigations

Strengthen defenses based on vulnerabilities identified during the attack.

💬 V. Communication Plan

V Communication Plan

V.1 Internal Communication

V.1.a

Notify leadership and affected departments immediately.

V.1.b

Provide regular updates during incident response.

V.2 External Communication

V.2.a

Inform customers or partners as required by law or contractual obligations. .

V.2.b

Comply fully with all applicable regulatory reporting requirements.

V.2.c

Prepare honest and transparent public statements when appropriate, focusing on steps being taken to address the incident and protect stakeholders.

V.2.d

Consult legal counsel to ensure all communications meet regulatory requirements

🎯 VI Key Performance Indicators (KPIs)

VI Key Performance Indicators (KPIs)

VI.1 Detection

VI.1.a Time to Detect (TTD):

Measure the duration between the onset of the incident and detection.

VI.1.b Mean Time to Respond (MTTR):

Measure the average time between incident detection and the initial response.

VI.1.c False Positive Rate:

Track the percentage of alerts that turn out to be false alarms to refine detection systems.

VI.2 Containment and Recovery

VI.2.a Time to Contain (TTC):

Measure how quickly the team isolates affected systems after detection.

VI.2.b Time to Recover Baseline Security Posture (TTRBSP):

Measure the time taken to restore security measures to their baseline state before the incident occurred.

VI.2.c Recovery Point Objective (RPO) and Recovery Time Objective (RTO) Achievement:

Track how often these predefined objectives are met during incident recovery.

VI.3 Efficiency and Effectiveness

VI.3.a Incident Closure Rate:

Percentage of incidents successfully resolved within defined timeframes.

VI.3.b Cost per Incident:

Track the financial impact of each incident, including response costs and potential losses.

VI.3.c Automation Efficiency:

Measure the percentage of incidents handled through automated responses versus manual intervention.

VI.4 Continuous Improvement

VI.4.a Post-Incident Improvement Rate:

Percentage of lessons learned that result in measurable security improvements.

VI.4.b Repeat Incident Rate:

Track the frequency of similar incidents to assess the effectiveness of implemented fixes.

VI.4.c Training Effectiveness:

Measure improvements in response times and outcomes after training sessions.

VI.5 Compliance and Satisfaction

VI.5.a Compliance Score:
Measure adherence to internal policies and external regulations during incident response.

VI.5.b Stakeholder Satisfaction:

Survey affected parties (internal and external) to gauge satisfaction with the incident handling process.

VI.6 Intelligence Utilization

VI.6.a Threat Intelligence Utilization:

Measure how often threat intelligence contributes to faster detection or resolution of incidents.

🧨 VII. Common Mistakes & Mitigations

VII Common Mistakes & Mitigations

VII.1 Overlooking early indicators

VII.1.a Mistake

Dismissing minor anomalies as false positives.

VII.1.b Mitigation

Automate alert prioritization in SIEM systems. Implement machine learning for anomaly detection. Conduct regular training on emerging threat indicators

VII.2 Inadequate documentation

VII.2.a Mistake

Failing to log actions during incident response.

VII.2.b Mitigation

Use automated tools to collect logs consistently across different systems and stages of incident response to minimize reliance on manual entry. Implement a standardized incident response template. Conduct periodic audits of documentation quality.

VII.3 Premature recovery

VII.3.a Mistake

Reconnecting systems before complete eradication.

VII.3.b Mitigation

Perform thorough validation before resuming operations. Implement a formal checklist for system recovery. Conduct staged recovery, starting with non-critical systems.

VII.4 Neglecting post-incident reviews

VII.3.a Mistake

Skipping post-mortem analysis due to time constraints.

VII.3.b Mitigation

Make reviews mandatory for incident closure. Schedule reviews immediately after incident resolution. Assign accountability for implementing lessons learned.

🛠️ VIII. Tools & Techniques

VIII Tools & Techniques

VIII.1 Detection

SIEM (Splunk, QRadar), IDS/IPS (Snort, Suricata), EDR (CrowdStrike, SentinelOne).

VIII.2 Containment

NAC (Cisco ISE), firewalls (Palo Alto, Fortinet), Endpoint isolation tools (Carbon Black Response).

VIII.3 Eradication

Antivirus/Antimalware (Sophos, Malwarebytes, Windows Defender).

VIII.4 Recovery

Backup solutions (Veeam, Acronis).
Threat Hunting, Vulnerability Scanning, and Patching

VIII.5 Analysis

Forensic tools (FTK, EnCase, Wireshark,).

🧰 IX. Review & Maintenance

IX Review and Maintenance

IX.1 Annual updates

Review and update the IRP at least annually, or more frequently if significant changes occur in the organization's structure, technology, or threat landscape. Incorporate lessons learned from actual incidents and simulations into the IRP.

IX.2 Ongoing Training

Conduct quarterly training sessions and simulations for the incident response team. Provide annual awareness training for all employees on basic incident reporting procedures. Update training materials to reflect current threats and best practices.

IX.3 Audits and Assessments

Conduct internal audits of the incident response process annually. Engage third-party experts for independent audits every 2-3 years to ensure objectivity and identify blind spots. Perform regular vulnerability assessments and penetration tests to proactively identify weaknesses.

Appendix

APPENDIX

capybara Unlimited

📚 Playbooks

IR PLAYBOOKS

👾 Malware Infection

Malware Infection Playbook

1. Identify and contain the malware

Quickly detect and limit the spread of the malware to minimize damage.

1.1 Identify and observe infected systems

Isolating infected systems safely without disrupting critical operations

1.2 Conduct preliminary analysis

Gather initial indicators of compromise (*e.g.,* suspicious files, processes, or connections) to inform containment strategies.

2. Perform static analysis of the malware sample

Analyze the malware file without executing it to understand its characteristics.

2.1 Inspect file structure and metadata

Examine the malware file's properties, including size, hash values, and embedded metadata.

2.2 Extract embedded strings and suspicious code

Use tools like VirusTotal to identify readable text and suspicious code within the file.

3. Perform dynamic analysis in a controlled environment

Observe malware behavior in real-time to understand its operational capabilities.

3.1 Execute malware on a clean system

Run the malware in a controlled environment to observe its effects in a real-world scenario and collect realistic forensic artifacts to assist in the identification of all affected systems.

3.2 Record system modifications and activities

Document changes to the registry, file systems, and active processes during execution.

4. Conduct network traffic analysis

Analyze communication attempts made by the malware to uncover external connections.

4.1 Capture network traffic

Use packet-capturing tools to monitor network activity generated by the malware.

4.2 Identify external entities

Look for connections to command-and-control (C2) servers or data exfiltration endpoints.

5. Investigate behavioral patterns and persistence mechanisms

Determine how the malware survives and operates over time.

5.1 Identify persistence techniques

Investigate changes such as registry modifications, scheduled tasks, or startup files.

5.2 Examine behavioral indicators

Look for recurring patterns, such as periodic network requests or file executions.

6. Eradicate the malware and recover systems

Remove the malware and restore affected systems to their original state.

6.1 Deploy cleanup tools

Use antivirus or specialized malware removal tools to eradicate infections.

6.2 Restore from clean backups

Reinstall systems and data using backups confirmed to be malware-free.

6.3 Apply mitigations to prevent reinfection

Address any vulnerabilities that permitted the original infection to occur by applying the appropriate mitigation.

7. Post-incident reporting and prevention

Document lessons learned and strengthen defenses against future incidents.

7.1 Generate incident report

Detail findings, response steps, and impact assessment in a comprehensive report.

7.2 Implement prevention measures

Update security policies, patch vulnerabilities, and educate staff to avoid recurrence.

🪝 Phishing

Phishing Playbook

1. Identify and verify the phishing email

Confirm that the suspicious email is a phishing attempt, not a legitimate message. Check the sender's IP address against known blacklists

1.1 Analyze email headers and content

Inspect email headers for inconsistencies like mismatched sender domains or unusual reply-to addresses. Review the content for generic greetings, poor grammar, or urgent requests for sensitive information.

1.2 Compare against known phishing indicators

Cross-check email elements against known phishing indicators, such as fake links (hover over to inspect URLs), suspicious attachments, or spoofed branding.

2. Contain the threat

Prevent further exposure or escalation.

2.1 Isolate the email

Instruct recipients not to click any links, open attachments, or reply. Move the email to a quarantined folder or flag it as phishing.

2.2 Notify IT/security team

Report the phishing email to the organization's security team immediately, following internal reporting procedures.

3. Investigate the impact

Determine the extent of the threat and affected users.

3.1 Verify user interaction

Assume someone interacted with the email. People might not want to admit they made a mistake, or they might not even realize they clicked a malicious link. Also rely on your network security monitoring.

3.2 Check affected systems

Use endpoint detection and response (EDR) tools to monitor devices for unusual activity or malware from potential downloads. Identify lateral movement or suspicious network activity.

4. Eradicate the threat

Remove malicious elements and secure compromised accounts or systems.

4.1 Remove phishing emails

Remove emails ASAP to prevent users from accidentally clicking those links.

4.2 Secure compromised accounts

If credentials were entered, reset passwords immediately and monitor account activity for unauthorized access. Enforce MFA on all accounts.

5. Educate and prevent future incidents

Strengthen user awareness and defenses.

5.1 Notify all employees

Quickly notify all employees that a phishing email is going around and what it looks like. Give an example of the email subject and sender to help them identify it in their inbox.

5.2 Provide training

Conduct phishing awareness sessions and simulated phishing exercises to reinforce detection skills.

6. Monitor and report

Ensure no residual threats remain and document the incident.

6.1 Monitor for reoccurrence

Track systems and user accounts for unusual activity linked to the phishing attempt.

6.2 Document the incident

Log the phishing attack, actions taken, and lessons learned to refine future response efforts.

🌊 Denial-of-Service

Denial-of-Service Playbook

1. Identify and characterize the attack traffic

Confirm the nature of the traffic to ensure it's consistent with a DoS attack rather than a legitimate traffic spike.

1.1 Automate detection of unusual number of packets

Utilize network and application monitoring tools to identify unusual traffic patterns. This includes excessive packet counts, abnormal request rates, and deviations from established baselines.

1.2 Classify the type of DoS

Characterize the traffic to determine if it aligns with known DoS attack patterns (*e.g.*, SYN flood, ICMP flood).

2. Measure traffic volume and bandwidth consumption

Accurately assess traffic volume to prioritize resources and decide on appropriate mitigation strategies.

2.1 Assess scope of DoS

Monitor network metrics to assess the scope, including packet size, rate of incoming requests, and bandwidth impact.

2.2 Evaluate impact of DoS

Use these metrics to understand the impact on network resources and how severely the attack affects performance. Monitor user experience. Log website loading times, application response times, and error rates.

3. Locate the source of attack traffic

Identify potential malicious sources to inform targeted blocking or rate-limiting actions.

3.1 Identify patterns in DoS traffic source

Use IP tracking and network monitoring to identify patterns in IP addresses, geographic sources, or ASN numbers.

3.2 Analyze identified patterns

Document any consistent IP ranges or indicators that suggest botnet involvement or attack origin.

4. Identify affected services and network components

Pinpoint affected systems to prioritize protective measures and service continuity efforts.

4.1 Identify affected internal systems

Use logs and network monitoring to determine which servers, services, or endpoints are being targeted by the attack (*e.g.,* web servers, DNS).

5. Implement and monitor mitigation measures

Ensure mitigation is effectively reducing malicious traffic while maintaining service availability for legitimate users.

5.1 Implement firewall rules

Employ a combination of network and application-level defenses to mitigate the attack. This may include rate limiting, traffic shaping, content filtering, blackholing, and leveraging cloud-based DDoS mitigation services. Configure defenses to minimize impact on legitimate user traffic.

5.2 Monitor effectiveness of firewall mitigations

Use network monitoring tools to continuously assess the effectiveness of these defenses.

6. Fine-tune mitigations and monitor:

Continuously analyze traffic patterns and adjust mitigation strategies to optimize performance and minimize false positives.

7. Revert to baseline monitoring:

Once the attack has subsided, remove temporary mitigations and revert to normal monitoring configurations. Analyze the incident and update security policies as needed.